GANRICH
ADVISORY

TEKNİK NOT · AB PAZARINA ERİŞİM

24 saat testi: AB’ye satış yapan üreticiler için CRA olay hazırlığı

Siber Dayanıklılık Yasası kapsamındaki bildirim yükümlülükleri 11 Eylül 2026’da başladı. Zor olan form değil; saatler içinde ne olduğunu ve kimin karar verdiğini bilmek.

Ahmed Furkan Gul, Kurucu, Ganrich Advisory

Ekim 2026

Yönetici özeti

> 1. 11 Eylül 2026’dan beri AB’de satılan dijital unsurlu ürünlerin üreticileri, ürünlerindeki aktif olarak istismar edilen açıkları ve ürün güvenliğini etkileyen ciddi olayları bildirmek zorunda: 24 saat içinde erken uyarı, 72 saat içinde bildirim ve ardından nihai rapor.
> 2. Yükümlülük üreticidedir. Bağlantılı cihaz, endüstriyel ekipman ve ticari yazılım üreten pek çok Türk üretici BT güvenliğine yatırım yaptı; ancak ürün olayları için belirlenmiş bir sahibi ve prova edilmiş bir yolu yok.
> 3. Hazırlık bir politika belgesiyle değil, tatbikatla kanıtlanır: belirlenmiş bir sorumlu, hızla bir araya getirilebilen ürün ve sürüm bilgisi, net bir karar kuralı ve zamanında gönderilebilecek taslak metin.

Ne değişti?

Siber Dayanıklılık Yasası, yani (AB) 2024/2847 sayılı Tüzük, AB pazarına sunulan dijital unsurlu ürünler için siber güvenlik gereklilikleri getiriyor. Ürün gerekliliklerinin çoğu 11 Aralık 2027’den itibaren uygulanacak; ancak bildirim yükümlülükleri daha erken, 11 Eylül 2026’da başladı.

Bir üretici, ürünündeki aktif olarak istismar edilen bir açıktan veya ürünün güvenliğini etkileyen ciddi bir olaydan haberdar olduğunda 24 saat içinde erken uyarı, 72 saat içinde daha kapsamlı bir bildirim ve tüzüğün belirlediği süreler içinde nihai rapor göndermelidir. Bildirimler, ENISA ile birlikte işletilen tek raporlama platformu üzerinden yetkili ulusal CSIRT’e iletilir.

Kapsam ürün bazında belirlenir. Her yazılım işletmesi kapsamda değildir ve tüzük küçük işletmeler için özel hükümler içerir. Korkuya dayalı okumalar kimseye yardımcı olmaz; net bir kapsam kontrolü olur.

24 saat neden zor?

Bilgi dağınık olduğunda 24 saat kısadır. Birinin istismardan haberdar olması gerekir; bu bilgi çoğu zaman bir müşteriden, araştırmacıdan veya tedarikçiden gelir. Birinin hangi ürün ve sürümlerin etkilendiğini çıkarması, birinin bildirim eşiğinin aşılıp aşılmadığına karar vermesi, birinin de bildirimi göndermesi gerekir. Pek çok üreticide bu kişiler bu amaçla hiç bir araya gelmemiştir.

BT güvenlik ekipleri ve yönetilen güvenlik hizmeti sağlayıcıları şirketin kendi sistemlerini korur. Ürün olayı ise farklıdır: müşterilerin elindeki cihaz ve yazılımları, mühendislikte duran sürüm geçmişini ve bileşen listelerini, satış veya destek ekibindeki müşteri iletişimini ilgilendirir.

Açık nadiren teknolojidir. Açık; sahiplik, bilgi ve provadadır.

Sık yapılan beş yanlış okuma

“SOC ekibimiz veya güvenlik sağlayıcımız bunu karşılıyor.” Onlar BT altyapınızı korur. Ürün bilgisi ve bildirim kararı üreticide kalır.

“CRA 2027’de başlıyor.” Ürün gereklilikleri öyle. Bildirim Eylül 2026’da başladı.

“Yalnızca doğrulanmış ihlalleri bildiririz.” Ürününüzdeki aktif olarak istismar edilen bir açık, kendi sistemleriniz hiç ihlal edilmemiş olsa bile bildirim gerektirebilir.

“Her yazılım şirketi kapsamda.” Kapsam ürüne ve ürünün AB pazarına nasıl ulaştığına bağlıdır. Önce kapsam kontrolü gelir.

“Yazılı bir prosedür hazırlığı kanıtlar.” Sürenin gerçekten karşılanıp karşılanamayacağını yalnızca tatbikat gösterir.

Yönetim ekibi için sorular

1. Hangi ürün ve sürümlerimiz AB pazarında ve hâlâ destekleniyor?
2. Mesai dışı dahil, ürün güvenliği olayının belirlenmiş sorumlusu kim?
3. Bir açığın istismar edildiğini nereden öğreniriz: müşteriler, araştırmacılar, tedarikçiler?
4. Etkilenen sürümleri ve bileşenleri saatler içinde belirleyebilir miyiz?
5. Bildirim eşiğinin aşıldığına kim karar veriyor?
6. Bildirimi kim gönderiyor ve raporlama kanalına erişimi şimdiden var mı?
7. Etkilenen müşterileri ve kullanıcıları nasıl ve ne zaman bilgilendiriyoruz?
8. Bir ürün olayını uçtan uca en son ne zaman prova ettik?

İyi bir ilk adımın ürettikleri

Yararlı bir ilk adım, tek bir ürün ailesinde 24 ve 72 saatlik takvime karşı yürütülen gerçekçi bir masa başı tatbikattır. Sonunda ekibin elinde kapsamdaki ürün ve sürümlerin haritası, belirlenmiş roller ve eskalasyon yolu, hazır bildirim taslakları ve sonuçlarına göre sıralanmış kısa bir açık listesi olmalıdır.

Ganrich Advisory bu tatbikatı tasarlar ve yürütür; bulgularını kapsamı belirlenmiş bir hazırlık planına dönüştürür. Ürün belgelendirmesi yapmaz, 7/24 olay müdahalesi yürütmez ve üreticinin

bildirim sorumluluğunu devralmayız; gerektiğinde uzman güvenlik ve hukuk ortakları görevlendirilir.

Görüşme başlatın

furkangul@ganrichadvisory.com · ganrichadvisory.com

Bu not hakkında. Bu not, 21–23 Ekim 2026 tarihlerinde kontrol edilen resmî kaynaklara dayanır. Genel bilgi niteliğindedir; hukuki, gümrük, vergi veya mühendislik danışmanlığı değildir. Kurallar, eşikler ve tarihler değişebilir; harekete geçmeden önce resmî kaynaklardan teyit edin. Herhangi bir müşteri çalışmasını veya sonucunu anlatmaz.

Kaynaklar: Avrupa Komisyonu, Siber Dayanıklılık Yasası – bildirim yükümlülükleri: digital-strategy.ec.europa.eu/en/policies/cra-reporting · (AB) 2024/2847 sayılı Tüzük (Siber Dayanıklılık Yasası), EUR-Lex

© 2026 Ganrich Advisory